

This playbook provides a structured, step-by-step process for detecting, containing, eradicating, and recovering from a ransomware incident for Nathan I Nyabvure LLC a financial technology organization that provides digital financial solutions to the African masses. Some of its financial solutions include mobile banking, virtual debit cards for processing online transactions. The company is medium sized company that operates in a highly government regulated financial industry. The baseline framework of the playbook is the NIST SP 800-61r2 and this because this framework is regarded widely considered the gold standard and primary framework choice for the U.S. government, federal agencies, and critical infrastructure. Apart from NIST the playbook also borrows from the SANS and this because the company is a small to medium size business. The two frameworks follow the same phases of Incident management lifecycle just a different way of presenting them and provided the playbook is organized around the phases and functions of these frameworks this makes this playbook a robust tool to respond quickly and effectively when security incident occur.

Preparation:

All items below should be completed before an incident occurs.

- Establish Incident Response Team
- Maintain and protect a current asset inventory. This includes knowing every endpoint, server, and cloud asset.
- Segment and document critical systems this includes the core banking systems and backup infrastructure and assign data classifications labels to these systems and infrastructure to guide priority during recovery.
- Document recovery time objectives (rto) and recovery point objectives (rpo) per system.
- Test restoration from backups in accordance with the backup policy. This is because untested backups are not reliable backups.
- Deploy EDR (Endpoint Detection & Response) across 100% of managed endpoints.
- Implement SIEM with correlation rules specific to ransomware TTPs
- Prepare Communication & Legal Readiness, this includes pre-preparing notification templates for customers, regulators and law enforcement.

Detection and Analysis

The following activities should be performed and completed because rapid, accurate detection and scoping is essential to effective containment.

- Identify Indicators of compromise: Endpoint Indicators (Unusual file extension changes, ransom note files README.txt). Network Indicators: Anomalous outbound data transfers, User reports, SEIM and EDR alerts.
- Document all findings with timestamps.
- Establish a chain of custody for all forensic evidence.
- Log all detection sources and timestamps in the incident ticket immediately.
- Perform an Incident Triage and Scoping

Containment, Eradication & Recovery

Following the NIST framework we have broken down this phase into short-term containment, evidence preservation and long-term containment, eradication, and recovery. The following steps must be adhered to:

- Decision point: balance isolation (stop spread) vs. Evidence loss (volatile data). Capture memory first.
- Isolate confirmed-compromised hosts at the network level
- Block malicious IPs, domains, and file hashes identified as IOCs.
- Disable compromised service accounts and user accounts, NOTE: do NOT simply reset passwords attacker may have persistence. Also do not shutdown isolate until forensic image is taken.
- Preserve east-west firewall rules and logs before making any changes.
- Notify NOC and help desk of isolation actions to prevent inadvertent reconnection.
- Disable SMB (port 445) and RDP (port 3389) internally if not required this is because ransomware commonly propagates via these protocols.
- Use Group Policy or EDR to kill known ransomware processes across the estate.
- Suspend or disable scheduled tasks and services associated with the attack.
- Consider taking critical, unaffected systems offline temporarily to protect them during active incident.
- Alert cloud teams to check cloud workloads for encryption activity and enable blob versioning if not already active.
- Define restoration priority order based on business criticality (Tier 1 → Tier 2 → Tier 3).
- Restore Tier 1 (critical business systems) first: Active Directory
- Restore Tier 2 (core business applications): Core banking system, email, customer-facing systems.
- Restore Tier 3 (general productivity): user workstations, non-critical servers.
- Monitor restored systems intensively for 72+ hours post-restoration and watch for re-encryption or re-compromise.
- Bring systems online in stages; do not reconnect the entire network simultaneously.
- Test business functionality at each tier before advancing to the next.

Post-Incident Activity:

Regulatory notifications, lessons-learned review, and strategic hardening improvements

Incident Handling for Small and Medium Businesses

Create notebookShareSettings

Sources

Add sources

Search the web for new sources

WebFast Research

Select all sources

NIST.SP.800-61r2.pdf

SANS.pdf

Chat

Summarise the documents and give me key takeaway points

The provided sources consist of two primary documents: **NIST Special Publication 800-61 Revision 2**, which serves as a comprehensive "Computer Security Incident Handling Guide" ¹ ², and a **SANS Institute White Paper** titled "An Incident Handling Process for Small and Medium Businesses," which adapts these processes for organizations with limited resources ³.

Summary of the Documents

NIST Special Publication 800-61 Revision 2 This guide provides a framework for organizations to establish a successful computer security incident response capability ⁴. It mandates that **Federal agencies must create and operate formal incident response capabilities**, including clear policies, plans, and procedures ⁵ ⁶. The document defines a **four-phase incident response life cycle**:

1. **Preparation**: Establishing tools, resources, and preventative controls ⁷ ⁸.

2. **Detection and Analysis**: Identifying signs of an incident (precursors and indicators) and prioritizing the response ⁹ ¹⁰.

Start typing...2 sources

Studio

Audio OverviewBETA Slide Deck

Video OverviewMind Map

ReportsFlashcards

QuizBETA Infographic

Data Table

id here. Audio Overview, and more!

NotebookLM can be inaccurate; please double check its responses.

ChatGPT

Share

when dealing with ransomware playbook main point to look into

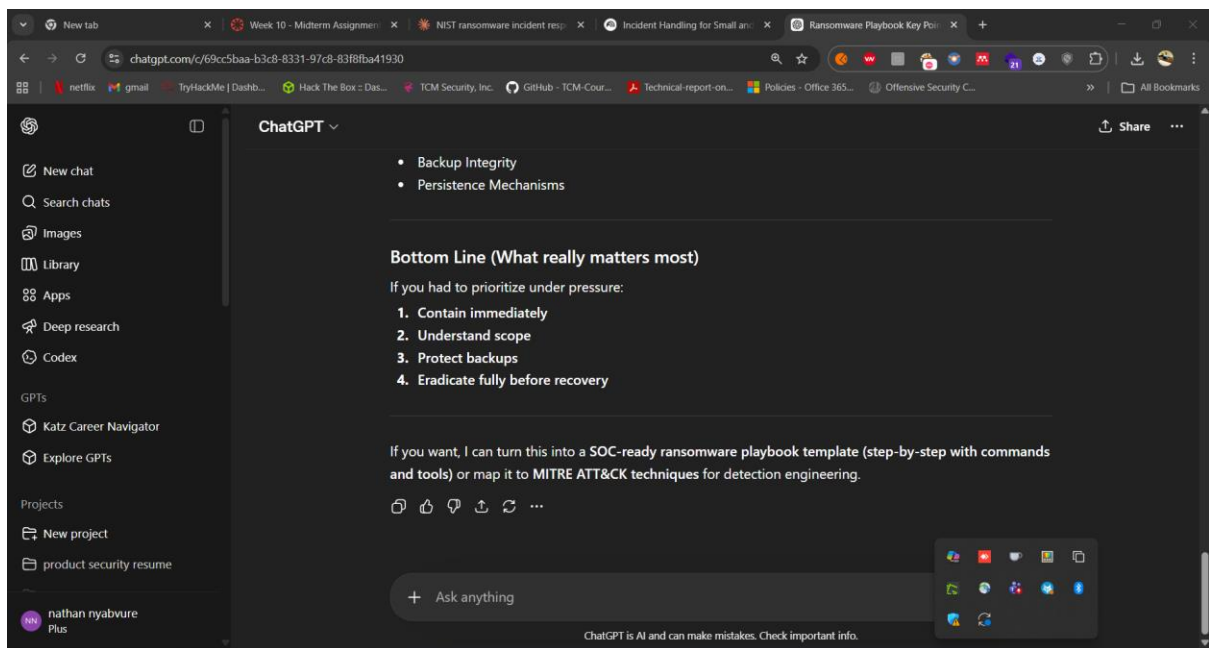
When you're building or executing a **ransomware incident response playbook**, the goal is simple: **contain fast, understand scope, preserve evidence, and recover safely**. The key is knowing what actually matters in the heat of the moment.

Here are the **main points you should focus on**, structured the way a strong SOC / IR team would approach it:

1. Early Detection & Identification

You need to confirm *this is ransomware* and not something else.

- Indicators of Compromise (IOCs):
 - Encrypted files / unusual extensions
 - Ransom notes appearing across systems
 - Sudden spike in CPU/disk activity
- Alerts from tools:



<https://chatgpt.com/share/69cc5c2f-9be0-832f-912a-5ac2e7f1d75d>